

INVARUNE BY NIMESHBUILD

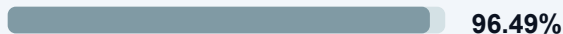
Better detection. Measured against the same evidence.

Benchmark update / Invarune 0.13.0

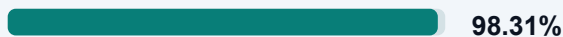
The unchanged development-visible fixture corpus and eight pinned public projects were scanned again after targeted detector fixes. This publication records the measured changes, comparison scope and unresolved work.

Precision

v0.12.0

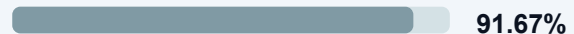


v0.13.0

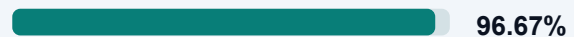


Recall

v0.12.0



v0.13.0



Unchanged fixture comparison	Observed result
Cases / original corpus	113 / 1.2.0
Previously failing cases now correct	4
New mismatches on previously correct cases	0
Remaining labeled mismatches	3
Pinned public-project scope	8 projects / 4,120 exported files
Current Invarune source observations / coverage gaps	146 / 15

These percentages describe project-authored rule-presence labels used during development. They are not production accuracy, independent validation or a claim that Invarune is better than every scanner.

[Interactive benchmark dashboard and downloadable evidence](#)

Read the evidence in layers

Fixture accuracy and unchanged labels

What was fixed and what still needs work

Source precision refinements

Fresh comparison on eight public projects

Finding overlap and complementary coverage

Why use invscan in an agent/MCP review

Reproduce, validate and inspect the complete ledger

Evidence layer	What it establishes
Deterministic fixtures	Agreement with explicitly authored rule-presence labels; supports regression and before/after analysis.
Public source observations	Patterns reported by configured tools on exact pinned files; requires source and deployment review.
Optional model review	Advisory judgments only when actually requested and completed; not a replacement for independent truth.
Runtime validation	Still needed for authentication, reachability, tenant isolation, prompt-injection resistance and deployed safeguards.

All measurements in this update preserve target isolation: no upstream project code, service or exploit was executed. Tool support, parser warnings and incomplete work remain visible.

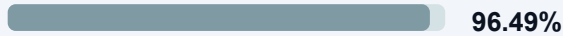
Fixture accuracy

The before and after runs use the exact same 113 cases, source bytes, paths and expected labels. Corpus SHA-256:

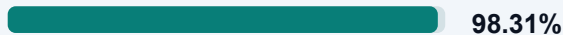
eb7f1eba93f8e9842634cbd12687dde5bea879505d99d367621214583e54dde3

Precision

v0.12.0

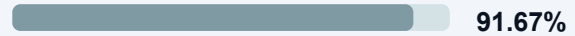


v0.13.0

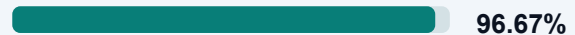


Recall

v0.12.0



v0.13.0



Outcome	Before 0.12.0	After 0.13.0
True positive	55	58
True negative	51	52
False positive	2	1
False negative	5	2
Analysis errors	0	0

Precision = $TP / (TP + FP)$. Recall = $TP / (TP + FN)$. A true-positive label here means that the designated detector correctly recognized the fixture's specified source pattern. It is not an independently confirmed vulnerability.

All challenge failures remain in these denominators. Default regression gating is a narrower CI policy and must not be read as zero mistakes. Fixes were developed with knowledge of these cases; this is a transparent development benchmark, not a held-out test.

[Before accuracy JSON](#)

[After accuracy JSON](#)

Fixes and remaining limits

Previously failing cases now agree with the unchanged label

Fixture	Bounded detector improvement
gap-reflection-python	Resolve a small literal or concatenated getattr attribute while respecting local shadowing.
gap-yaml-alias	Resolve a supported preceding same-document literal anchor without evaluating tags or general alias graphs.
gap-yaml-block-string	Mask YAML scalar contents before configuration-key checks; documentation is data.
gap-shell-wrapper	Recognize a direct downloaded command substitution passed as shell -c command text.

Still unresolved on this corpus

Fixture	Remaining mismatch
gap-interprocedural-url	Cross-function argument flow needs interprocedural analysis.
gap-js-wrapper-taint	JS wrapper argument flow is not whole-program taint analysis.
gap-validated-user-url	Constraint solving could prove this branch restricts the request to a fixed destination.

The release's paired and adversarial regression tests cover the supported interpretations and counterexamples. General interprocedural flow, dynamic runtime values, full YAML semantics and arbitrary shell expansion are not proven by these targeted changes. Review an uncertain finding in context instead of silently suppressing it.

[Detailed change analysis and remaining gaps](#)

Less noise on the same source

On the same 4,120 exported files, Invarune observations changed from 149 to 146. The source review identified three narrowly defined false-alarm patterns. Their removal is a precision refinement, not evidence that the target projects fixed vulnerabilities.

Observed source role	Detector correction
AutoGen: local requirements dot path	A local self-install path is no longer treated as an unpinned named dependency range.
CrewAI: api_key_env_var identifier	An explicit environment-variable-name field with an uppercase identifier is distinguished from a literal credential value.
AutoGen: all-x token placeholder	Recognized token formats now share the narrow all-x placeholder filter; realistic token-like literals remain review signals.

Evidence spans also became more precise

An OpenHands image-reference observation moved its starting line from a preceding blank line onto the image field. The delta ledger records the old/new identities transparently; this is one location refinement, not a newly discovered risk.

Coverage did not improve by dropping inputs

All eight pinned revisions, source manifests and scan budgets were held stable. Invarune examined 4,081 files, with 15 explicit coverage gaps. Unsupported extensions remain outside analysis. The benchmark preserves those limits instead of treating them as clean results.

[Exact source observation delta](#)

[Scoped source review, rationale and pinned evidence](#)

[Download all eight detailed source reports](#)

Eight projects. Fresh executions.

The same exported first-party source/configuration bytes were offered to Invarune, Semgrep CE, Bandit and Gitleaks. Equal input does not make their languages, rule scope or supported inputs identical. Counts below are observations, not unique vulnerabilities.

Project	Files	Invarune	Semgrep	Bandit	Gitleaks
autogen	786	11	6	183	0
crewai	968	27	8	232	0
fastmcp	283	0	2	95	1
github-mcp	163	15	1	unsupported	0
langgraph	211	23	8	84	1
mcp-reference	86	61	0	0	0
openhands	1237	9	0	unsupported	1
pydantic-ai	386	0	2	344	0

Tool	Recorded version	Observations	Scope status
Invarune	0.13.0	146	4 completed; 4 completed_with_analysis_gaps
Semgrep CE	1.177.0	27	1 completed_no_findings; 3 completed_with_analysis_errors; 4 completed_with_findings
Bandit	1.9.4	938	1 completed_no_findings; 1 completed_with_analysis_errors; 4 completed_with_findings; 2 unsupported_no_python_files
Gitleaks	8.30.1	3	5 completed_no_findings; 3 completed_with_findings

Invarune reports 15 coverage gaps. Those inputs are incomplete, not clean. Semgrep parser warnings, Bandit parser errors and unsupported exports are retained in the run-status receipts. All eight Invarune projects have two byte-identical repeated outputs under the recorded runtime and settings.

[All normalized run statuses and coverage details](#)

What overlaps - and what does not

A compatible family, the same pinned project/path and intersecting line spans are required for a match. One-to-one pairs require exactly one candidate on each side. Ambiguous and location-only relations remain separate; matching does not establish a true-positive label.

Compared with	1:1 pairs	Ambiguous edges	Invarune unmatched	Other tool unmatched
Semgrep CE	7	0	139	20
Bandit	12	5	129	925
Gitleaks	1	0	145	2

The complete ledger exposes what each scanner reported, the other-tool match candidates, exact pinned paths and rule-family predicates. A tool-only record may reflect useful additional scope, a differently defined rule, unsupported analysis, a false alarm or a genuine missed risk; count alone does not decide which.

Native findings remain review signals

Broad source scanners can surface assertions, weak-hash uses, serialization APIs and import-only records. Invarune emphasizes selected agent/MCP configuration and execution risks with control/source mappings. Secret scanners, dependency/CVE scanners and runtime/adversarial tests add other evidence. No tool is awarded false positives merely because another tool lacks the same rule.

No new ground-truth percentage is claimed for public projects

This deterministic rerun does not perform Claude adjudication or independent exploit validation. Earlier model-authentication failures remain historical failures, and earlier selected source audits remain separate evidence. Confirmed-vulnerability precision and public-project recall are unavailable.

[Complete finding-by-finding ledger](#)

[Machine-readable overlap and unmatched sets](#)

An agent/MCP review workflow

Invarune's value is the traceable review workflow around selected security checks. These are product capabilities documented and tested by this project, not a score against untested competitor editions.

Capability	How to use the evidence
Source or built Linux image	Inspect supported source/configuration and image metadata without starting target code or a container. Compiled-only logic remains unassessed.
Offline control explorer	Use <code>invscan --ask</code> and explain commands without a model, login or network. Each answer explains control meaning, sources and limits.
42 rules / 66 controls / 132 checks	Rules partially map to 26 controls; the remaining controls and complete acceptance checks need other evidence. No inferred compliance pass.
Concrete remediation	Reports connect findings to agent/MCP context, proposed fixes, verification steps and possible mitigating layers. Undeployed defenses do not lower risk automatically.
Optional bounded AI review	Enable official CLI or API/gateway review explicitly. Deterministic validation constrains evidence/citations/budgets; model judgments stay advisory.
Review and justification roundtrip	Carry edited supported report inputs into a fresh scan. Accepted justifications stay justified, excluded from the applicable scored denominator, and retain evidence bindings.

Use complementary runtime validation for MCP authorization, tenant separation, sandbox escape resistance, egress enforcement and prompt-injection task outcomes. A repository or image cannot establish the deployed identity, network policy or human approval process.

[CLI quick start](#)

[Controls, benchmarks and primary source mappings](#)

Reproduce and audit the result

Every published count is derived from the linked local execution artifacts. The PDF builder rejects mismatched fixture hashes/labels, invalid ledger totals, overlap partition errors, mismatched scanner versions and changed before/after project inputs.

Input	SHA-256
accuracy-before.json	317df5794e85e17d4c5965023ff1fddfb708262bb94f5fb3f517f265994a6a94
accuracy-after.json	49bd49b0464b288beca29212d1b8be4f3b6c48ce5037a0da771bc2c829de9e38
observations.json	668f465110aa4f47ea3a89df5cbf0a509b69980bfa9cebe5ffee8a601f221721
overlaps.json	c4c4510045638675b37919f8c040a3661e420f44d7f1f57cbc023278c613713b
run-status.json	1f63d714a1cbd5cf95f88ebef01a23ecc55f02400ef323a918fc412c218a83eb
baseline-identity.json	8ca33faac8770a910638e53ac60188fc8be34087f00de74bd49bcc3864ee1c14
before-after-accuracy.json	bf763bc4b484466a9ef632cff766331e66b687c5106e0774973e439d56ff0a79

Reproduction sequence

1. Read the v0.13 benchmark README and exact tool/source lock.
2. Recreate the pinned source exports and verify their manifests.
3. Run the frozen baseline and final scanner independently; preserve both receipts.
4. Run the recorded external versions and rule pack on the same exports.
5. Regenerate the exhaustive observation/overlap ledger and fixture evaluations.
6. Build the dashboard/PDF from those receipts, then render and visually inspect every page.

[v0.13 reproduction protocol and tool configuration](#)

[Source selection and pinned repositories](#)

[PDF and site authoring instructions](#)

Invarune by NimeshBuild is an original engineering synthesis. Referenced publishers and compared projects do not endorse it. Third-party materials retain their own terms. Public repository visibility does not independently grant an open-source license.